Quick assessment: Harbor Claims Portal (legacy Java)

> Fictional demo system. Everything below is generated from `assess/results/` by `assess report`. Nothing is typed by hand. Vulnerability data as of 2026-10-05.

Summary

The portal has 35 Struts actions across 5 business modules plus a shared platform, 25 JSPs and 74 Java files (5360 lines). Move Customers first. Leave Reports and Admin alone. Migrating the modules worth moving (Reports and Admin are left alone) is roughly 88.5 to 225 ideal person-days, about 12.5 to 32.5 calendar weeks for 2 developers.

System inventory

Module	Actions	JSPs	Java files	Java lines	Scriptlet blocks
Customers	6	3	9	620	5
Claims	6	3	14	1963	2
Policies	7	3	16	1200	5
Reports	5	4	7	273	0
Admin	7	4	10	536	0
Platform	4	8	18	768	31
All modules	**35**	**25**	**74**	**5360**	**43**

- 35 action mappings (2 are plain forwards, 31 custom action classes), 8 form beans and 20 Tiles definitions.
- 25 JSPs with 43 scriptlet blocks (26 scriptlets, 17 expressions, 0 declarations).
- 6 roles held in a database table: admin, adjuster, supervisor, underwriter, csr, auditor.
- Request filters, in order: encoding, login. Roles are checked per action with the Struts roles attribute on 21 of 35 mappings.
- 6 DAOs and 6 managers over plain JDBC. Integrations found: JNDI DataSource, PostgreSQL JDBC driver (container-provided), Quartz scheduler (nightly batch), Struts 1 MVC, Tiles 1 page layout, iText PDF export, log4j 1.x logging.

Top risks

Ranked by likelihood times impact, one entry per root cause. At most 3 entries come from any one group, so the list is not just the worst CVEs. The full register has 17 entries in `assess/results/risks.json`.

Rank	Risk	Evidence	Likelihood	Impact	Score
1	SQL built by string concatenation (CWE-89)	3 query sites	5	5	25
2	Passwords stored and compared in plaintext (CWE-256)	1 comparison site	4	5	20
3	postgresql 42.2.27 (provided by the container, not in the WAR)	3 advisories (1 critical, 1 high, 1 medium)	4	5	20
4	commons-collections 3.2.1	2 advisories (1 critical, 1 high); superseded	4	5	20
5	log4j 1.2.17	6 advisories (3 critical, 3 high); end of life since 2015-08-05	4	5	20
6	Admin actions without a role check (CWE-862)	2 actions	5	4	20
7	Struts 1 has no Jakarta build, so it blocks a javax to jakarta upgrade	91 javax.servlet imports in 42 files	5	4	20
8	Business rules are recorded only in code	assumption, confirm with the client	4	3	12
9	God class	ClaimManager (1122 lines)	5	2	10
10	Package dependency cycles	2 cycles: auth + common; claims + customers + policies	5	2	10

6 risks were left out of this list by the per-group cap: quartz 1.8.6; struts-core, struts-extras, struts-taglib, struts-tiles 1.3.10; itext 2.1.7; commons-beanutils 1.8.0; bcmail-jdk14, bcprov-jdk14, bctsp-jdk14 1.38; State-changing forms without an anti-CSRF token (CWE-352).

Dependency and CVE summary

The WAR holds 22 jars (2 duplicates). OSV lists 36 unique advisories against 9 of its libraries; 11 libraries have no OSV records, which is not the same as clean. 8 libraries are end of life, unmaintained or superseded.

Severity	Advisories in the WAR
CRITICAL	5
HIGH	19
MEDIUM	11
LOW	1
UNKNOWN	0

Most severe advisories affecting the WAR:

Advisory	Library	Severity	Score	Summary
CVE-2015-7501	commons-collections:3.2.1	CRITICAL	9.8	Deserialization of Untrusted Data in Apache commons collections
CVE-2019-13990	quartz:1.8.6	CRITICAL	9.8	XML external entity injection in Terracotta Quartz Scheduler
CVE-2019-17571	log4j:1.2.17	CRITICAL	9.8	Deserialization of Untrusted Data in Log4j
CVE-2022-23305	log4j:1.2.17	CRITICAL	9.8	SQL Injection in Log4j 1.2.x
CVE-2022-23307	log4j:1.2.17	CRITICAL	9.8	Deserialization of Untrusted Data in Apache Log4j

End-of-life and unmaintained frameworks:

Library	Status	Since
commons-collections 3.2.1	SUPERSEDED	n/a
itext 2.1.7	UNMAINTAINED	2009
log4j 1.2.17	EOL	2015-08-05
quartz 1.8.6	SUPERSEDED	n/a
struts-core 1.3.10	EOL	2013-04-05
struts-extras 1.3.10	EOL	2013-04-05
struts-taglib 1.3.10	EOL	2013-04-05
struts-tiles 1.3.10	EOL	2013-04-05

3 further advisories affect libraries the container provides (postgresql), which are not in the WAR and are counted separately.

Recommended approach

Use a strangler-fig migration. Customers can move first: coupling to the rest of the code is low, so it can be cut out with the least untangling. Fix the security findings in the legacy app first (Phase 0), then stand up the platform and move the first slice.

Approach	Verdict	Effort (ideal person-days)	Why
Strangler fig behind a gateway	Recommended	88.5 to 225	Legacy and Spring Boot 3 run side by side. Modules move one at a time behind characterisation tests, so risk is spread and nothing waits for a final cutover.
Big-bang rewrite	Not recommended	94.5 to 243.5	Its band also covers the modules the strangler plan leaves alone. For the same modules it is 68 to 173 on paper, because it skips the gateway, the bridge and the Phase 0 double work. The catch: every module, the God class and the cycles must be solved before anything ships, and nothing is released until it is all done.

Approach	Verdict	Effort (ideal person-days)	Why
Lift: upgrade Java and the container in place	Blocked	not applicable	Struts 1 has no Jakarta build. The OpenRewrite dry run would change 45 files, yet struts-core would still need javax.servlet (91 imports in 42 files).

Module order, from the scoring in the estimation model:

Module	Business value	Coupling per class	Band	Decision	Phase
Customers	3	0.44	LOW	Migrate first	Phase 1
Claims	5	1.07	MEDIUM	Migrate later (first slice only)	Phase 1
Policies	4	1.25	MEDIUM	Migrate later	Phase 3
Reports	2	1.14	MEDIUM	Leave alone	none
Admin	1	0.5	LOW	Leave alone	none

Claims: Only the in-scope actions move first (the M6 proof slice); the rest follows its score. Business values are assumptions to confirm with the client.

Rough effort band

Migrating the modules worth moving (Reports and Admin are left alone) is roughly 88.5 to 225 ideal person-days, about 12.5 to 32.5 calendar weeks for 2 developers.

Phase	Work	Effort (ideal person-days)
0	Security quick fixes in the legacy app	14 to 37.5
1	Platform, gateway and first slice (Customers, Claims)	48.5 to 115
2	Migrate the rest of Claims	8.5 to 23.5
3	Migrate Policies	17.5 to 49

Left alone and not in the total, with the cost of migrating them in brackets: Reports (13 to 35), Admin (13.5 to 35.5).

Caveats and assumptions

There is no Jakarta-compatible Struts 1: after the rewrite, struts-core still needs javax.servlet. The changed-file count measures the javax surface, not whether a migration is feasible.

- Effort is in ideal person-days as a low to high band. Bands add lows and highs separately: a hard band, not a confidence interval.
- Calendar time assumes 2 developers at a focus factor of 0.7.
- Unit rates, multipliers and business values are labelled assumptions in `assess/estimation-model.yaml`, each with a rationale. They are inputs, not measurements.
- Fixes made in the legacy app in Phase 0 are partly thrown away when the code is rewritten: deliberate double work.

Generated by assess 1.0.0. Inputs fingerprint 80fb06bd57d2. Security scan by Semgrep 1.176.0 with the local ruleset. End-of-life table as of 2026-10-05.